Cybersecurity Engineer Assessment: Summary

Candidate: Talal Rehan | **Prepared:** 21 September 2026 | **Full detail:** `01_Full_Solution_Pack.pdf` (Parts 1-20, Bonus, disclosure)

> **Bottom line.** Apex's biggest risks are basic access and exposure failures (no MFA, shared admin, database and admin paths open, keys on laptops) plus two AI-specific gaps: patient data in prompts, logs and an external LLM, and agents and RAG not limited by authorization. Eight of 19 findings score Critical. Five bundled fixes remove the shortest paths to patient data within 72 hours.

If I Had One Day to Secure Apex

#	Action	Owner	Proof it worked
1	Enforce MFA everywhere, admins first (FIDO2 for admins)	IT Lead + Security	IdP report: 100% of privileged users; no-MFA login refused
2	Retire the shared cloud admin; named admins via SSO; sealed break-glass	CTO + Security	Shared account disabled, zero active keys; break-glass alert fires
3	Remove developer IPs from the production DB firewall; private only	DevOps	Before/after rule export; port test closed
4	Admin interface behind ZTNA/VPN + SSO; block /admin at the gateway	DevOps	Public request to /admin blocked (log)
5	Rotate keys on laptops and the committed key; secrets manager; push protection	DevOps	Old keys rejected; history scan clean
6	Stop PHI in logs and to the external LLM (flag); restrict log store; purge only after Legal confirms	Backend + AI + DPO	Metadata-only log sample; egress logs show no PHI
7	Constrain agents and RAG: disable create_user and delete_record, approval for write tools, read-only scoped token, per-tenant index	AI Lead + Security	Tool-call matrix denies; cross-tenant canary returns nothing
8	Gateway/WAF baseline: rate limits, size limits, per-tenant token budget	Backend + DevOps	429 at limit; WAF blocks probe strings
9	Central minimum logs, five alerts (D02, D03, D06, D07, D13), one-page incident runbook	Security	Fire drill: each alert triggered once
10	Start production-DB restore test; report-only scans in CI; first asset inventory	DevOps	Restore log with RTO/RPO; first scan report

Order logic: identity first (control-plane compromise voids other fixes), then direct paths to data, secrets, data leakage, AI limits, and finally visibility and recovery.

One line per part

Part	My answer
1 Risk	19 findings scored likelihood x impact: 8 Critical, 9 High, 2 Medium. Five bundled P0 fixes, 90-day roadmap.
2 Architecture	Hardened edge, private tiers with default-deny, separate accounts, AI egress gateway and tool gateway; 7 trust boundaries.
3 IAM	No standing privileged access: JIT up to 4 h, FIDO2 for admins, sealed break-glass, joiner/mover/leaver and reviews.
4 Secrets	Assume the key was compromised for 6 weeks: replace then revoke (revoke at once if misuse), review logs, scan history, prevent.
5 DB access	No direct developer access. Synthetic non-production data; JIT read-only via a proxy; migrations through the pipeline.
6 Containers	18-item checklist; insecure Dockerfile corrected (non-root, no secrets, pinned, multi-stage). Not built here: marked [Design].
7 API	16 controls; object-level authorization first; matrix across the four endpoints.
8 Vulnerabilities	5 SLA tiers using a risk-adjusted score (exploited, exposed, data, reachable, compensating control), not CVSS alone.
9 CI/CD	Four gates (PR, build, stage, admission), signed artifacts, OIDC short-lived access, protected pipeline.
10 Logging	15 log sources, 16 detections, heartbeat on every source so silence alerts.
11 Incident	Least-disruptive containment first (revoke credential, block destination), scope, Legal/DPO notification decisions.
12 AI threats	14 threats mapped to OWASP LLM; assume the model can be steered, so controls sit outside the model.
13 RAG	Authorization-aware retrieval: pre-filter, policy re-check, fail closed, canary tests.
14 Agent tools	7 tools: autonomous, restricted, human-approved or prohibited, enforced by a tool gateway.
15 Data protection	Classes C0-C4; PHI tokenized before any external model; retention proposals to validate.
16 Saudi mapping	NCA ECC/CCC/DCC, PDPL, ISO, NIST, CIS at topic level. Requires legal/compliance validation.
17 Linux	20 checks, each with a command and pass criterion.
18 Hands-on	16 detection rules; 50 tests pass; 12 of 12 injected bugs caught; 0 false alerts on the benign day; 11 of 11 attack scenarios detected. Synthetic data only.
19 Executive	"Not yet." Foundations are good; logins, configuration and AI features are the risk. Conditional go with 12 evidence items.
20 Demo day	Fix / mitigate / accept / defer rules applied to ten illustrative findings (the brief did not supply them).
Bonus	Challenge the "secure enough" position: accept the speed goal, change to a conditional go on synthetic data.

Assumptions note

- No facts about Apex beyond the brief were used; nothing not stated is treated as compliant. No real system was accessed.
- Cloud provider unspecified; design is cloud-neutral and tool names are examples.
- Scores and thresholds are engineering judgement on stated scales, not measurements.
- Saudi regulatory mapping is at topic level and Requires legal/compliance validation.
- The ten Part 20 findings were not supplied; the ten used are illustrative and labelled.

AI and tools disclosure

Item	Disclosure
Tools	Claude (Anthropic) for drafting structure, text, diagram code and detection code. Python 3 and matplotlib. ReportLab for the PDF.
What AI accelerated	First drafts, code scaffolding, formatting and consistency checks across the 20 parts.
Verified by execution	50 unit tests, a 12-mutant check and an evaluation run (outputs in folder 03). One test gap found by the mutation check was fixed.
Not independently verified	Regulatory references, product names, scores and thresholds, Dockerfile build, YAML and shell snippets outside folder 03.
My own judgement	Priorities, decisions and thresholds are confirmed by me and I can explain each in the live defence.